

BÁO CÁO DỰ ÁN

HỆ THỐNG CHAT SERVER BẢO MẬT

Người thực hiện: Tên của bạn

Giáo viên hướng dẫn: Tên GVHD

Tháng 06 năm 2026

TÓM TẮT NỘI DUNG DỰ ÁN

Dự án tập trung vào việc thiết kế và phát triển một hệ thống máy chủ trò chuyện trực tuyến (Chat Server) đa luồng, có khả năng mở rộng cao và được tích hợp các cơ chế bảo mật toàn diện. Hệ thống được xây dựng hoàn toàn bằng ngôn ngữ C++ dựa trên kiến trúc Client-Server thông qua giao thức TCP. Để tối ưu hóa hiệu năng và độ linh hoạt, dự án đã thiết kế một giao thức truyền tải tùy chỉnh (Custom Protocol) thay vì các giao thức văn bản thông thường. Giao thức này hỗ trợ đa dạng các nghiệp vụ thời gian thực như nhắn tin cá nhân, trò chuyện nhóm (room), truyền tải tệp tin, và các tập lệnh quản trị hệ thống (admin commands).

Điểm khác biệt cốt lõi của dự án nằm ở hệ thống an toàn thông tin nhiều lớp. Quá trình kết nối được bảo vệ bởi một quy trình bắt tay (Handshake) tùy chỉnh: sử dụng thuật toán bất đối xứng RSA để trao đổi khóa an toàn, sau đó áp dụng mã hóa đối xứng AES cho mọi dữ liệu truyền tải. Để chống lại việc giả mạo và đánh tráo gói tin, hệ thống sử dụng mã xác thực thông điệp HMAC kết hợp hàm băm SHA256. Không chỉ dừng lại ở mã hóa đường truyền, máy chủ còn được trang bị module Phát hiện xâm nhập (Intrusion Detector) để ngăn chặn các kết nối độc hại, cùng với hệ thống Nhật ký kiểm toán chống can thiệp (Tamper-evident Audit Logger) lưu trữ trên cơ sở dữ liệu SQLite, giúp đảm bảo tính minh bạch và an toàn tuyệt đối cho dữ liệu truy vết.

Về mặt kiến trúc phần mềm, máy chủ vận hành dựa trên cơ chế vòng lặp sự kiện bất đồng bộ (Event Loop) kết hợp với mô hình Thread Pool, giúp giải quyết triệt để bài toán xử lý đồng thời lượng lớn kết nối (C10K) với độ trễ tối thiểu. Kết quả của dự án là một nền tảng giao tiếp mạnh mẽ, đáp ứng đầy đủ các tiêu chuẩn khắt khe về hiệu năng và an ninh mạng trong môi trường thực tế.

Mục lục

Danh sách hình vẽ	iii
Danh sách bảng	iv
Bảng từ viết tắt	v
CHƯƠNG 1. KHẢO SÁT VÀ PHÂN TÍCH YÊU CẦU	1
1.1 Khảo sát hiện trạng	1
1.2 Phân tích yêu cầu hệ thống	2
1.2.1 Yêu cầu chức năng	2
1.2.2 Yêu cầu phi chức năng	2
CHƯƠNG 2. NỀN TẢNG LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG	3
2.1 Kiến trúc mạng và giao thức	3
2.1.1 Mô hình Client-Server	3
2.1.2 Giao thức TCP/IP	3
2.2 Công nghệ mã hóa và bảo mật	3
2.2.1 Mã hóa đối xứng AES	3
2.2.2 Mã hóa bất đối xứng RSA	3
2.2.3 Hàm băm SHA256 và xác thực HMAC	3
2.3 Công cụ và Thư viện phát triển	3
CHƯƠNG 3. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ	4
3.1 Kiến trúc tổng thể hệ thống	4
3.1.1 Kiến trúc Server	4
3.1.2 Kiến trúc Client	4
3.2 Thiết kế giao thức giao tiếp	4
3.2.1 Cấu trúc gói tin	4
3.2.2 Luồng xử lý thông điệp	4
3.3 Thiết kế cơ chế bảo mật	4

3.3.1	Cơ chế trao đổi khóa (Key Exchange)	4
3.3.2	Xác thực chứng chỉ số	4
3.4	Triển khai và Đánh giá	4
3.4.1	Môi trường triển khai	4
3.4.2	Đánh giá kết quả đạt được	4
CHƯƠNG 4. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN		5
4.1	Kết luận	5
4.2	Hướng phát triển	5

Danh sách hình vẽ

Danh sách bảng

BẢNG TỪ VIẾT TẮT

Từ viết tắt	Ý nghĩa
TCP	Transmission Control Protocol
TLS	Transport Layer Security
AES	Advanced Encryption Standard
RSA	Rivest-Shamir-Adleman

CHƯƠNG 1. KHẢO SÁT VÀ PHÂN TÍCH YÊU CẦU

1.1 Khảo sát hiện trạng

Sự bùng nổ của mạng Internet và các thiết bị kết nối đã làm thay đổi hoàn toàn phương thức giao tiếp của con người. Các ứng dụng nhắn tin và gọi điện trực tuyến (Chat Applications) đã trở thành một công cụ không thể thiếu trong đời sống cá nhân cũng như trong quá trình vận hành doanh nghiệp. Các hệ thống lớn như Zalo, Messenger, Telegram hay WhatsApp hiện đang đáp ứng nhu cầu giao tiếp cho hàng tỷ người dùng thường xuyên trên toàn cầu.

Tuy nhiên, đi kèm với sự phát triển nhanh chóng đó là những thách thức ngày càng nghiêm trọng về an toàn và bảo mật thông tin. Thực tế cho thấy, nhiều hệ thống giao tiếp hiện nay vẫn bộc lộ các lỗ hổng trong khâu lưu trữ và truyền tải dữ liệu. Các cuộc tấn công mạng nhằm đánh cắp danh tính (Identity Theft), nghe lén (Eavesdropping) hay tấn công trung gian (Man-in-the-Middle - MitM) ngày càng trở nên tinh vi. Một số giải pháp phổ biến thường phụ thuộc hoàn toàn vào các giao thức bảo mật lớp vận chuyển (như TLS/SSL) kết hợp với hạ tầng dịch vụ đám mây của bên thứ ba. Mặc dù các cơ chế này cung cấp mức độ bảo vệ cơ bản, nhưng chúng lại không đảm bảo được tính riêng tư tuyệt đối (Absolute Privacy) và không cho phép các tổ chức có yêu cầu an ninh khắt khe làm chủ hoàn toàn luồng dữ liệu của mình.

Thêm vào đó, nhiều nền tảng giao tiếp mã nguồn mở hiện có lại sử dụng các giao thức dựa trên văn bản (Text-based protocols) khá cồng kềnh, gây hao tốn băng thông và gặp nút thắt cổ chai khi phải xử lý đồng thời hàng chục nghìn kết nối (bài toán C10K). Quá trình ghi nhận nhật ký hệ thống (Logging) ở các nền tảng này cũng thường được lưu dưới dạng file văn bản thuần (plain-text) dễ bị chỉnh sửa và xóa dấu vết, thiếu đi cơ chế kiểm toán chặt chẽ để truy vết nguồn gốc khi xảy ra sự cố rò rỉ dữ liệu.

Từ những hiện trạng nêu trên, việc nghiên cứu và tự xây dựng một hệ thống máy chủ trò chuyện (Chat Server) với kiến trúc đa luồng tối ưu, sử dụng giao thức truyền tải tự định nghĩa (Custom Protocol) cùng các lớp mã hóa bảo mật từ tận mức ứng dụng (áp dụng các thuật toán chuẩn như AES, RSA, HMAC) là vô cùng cấp thiết. Một giải pháp đồng bộ từ tầng mạng đến tầng ứng dụng không chỉ giúp làm chủ hoàn toàn công nghệ lõi mà còn tạo ra một môi trường giao tiếp đáng tin cậy, chống lại các hành vi giả mạo và cung cấp khả năng kiểm toán chống can thiệp (Tamper-evident Auditing).

1.2 Phân tích yêu cầu hệ thống

1.2.1 Yêu cầu chức năng

Dựa trên mục tiêu xây dựng một nền tảng trò chuyện bảo mật toàn diện, hệ thống cần đáp ứng các nhóm yêu cầu chức năng cốt lõi sau:

- **Quản lý phiên kết nối và người dùng:** Hệ thống phải hỗ trợ người dùng kết nối (Connect), ngắt kết nối (Disconnect) và duy trì trạng thái hoạt động thông qua cơ chế nhíp tim (Ping/Pong). Hệ thống cũng cần cho phép người dùng tra cứu danh sách những tài khoản đang online và xem thông tin chi tiết (Whois) của một người dùng cụ thể.
- **Giao tiếp và Nhắn tin:**
 - *Nhắn tin cá nhân (Private Chat):* Cho phép hai người dùng trao đổi thông điệp trực tiếp với nhau một cách bảo mật.
 - *Nhắn tin nhóm (Room Chat):* Hỗ trợ tính năng tra cứu danh sách phòng (List Rooms), tạo phòng mới (Create Room), tham gia (Join), rời phòng (Leave) và gửi tin nhắn quảng bá (Broadcast) tới tất cả các thành viên trong phòng.
- **Truyền tải tệp tin (File Transfer):** Hệ thống cần tích hợp tính năng gửi và nhận tệp tin P2P hoặc thông qua server. Quá trình này bao gồm các bước kiểm soát chặt chẽ: gửi yêu cầu truyền tệp (File Request), chấp nhận/từ chối (Accept/Reject), và truyền dữ liệu theo từng khối (File Data) để không gây nghẽn luồng thông điệp chính.
- **Quản trị hệ thống (Admin Commands):** Cung cấp đặc quyền cho quản trị viên thực hiện các thao tác kiểm duyệt, quản lý cộng đồng như: kích xuất người dùng (Kick), cấm chat (Mute), cấm truy cập (Ban), thăng cấp quản trị (Promote) và gửi thông báo toàn hệ thống (System Broadcast).
- **Thiết lập bảo mật sơ khởi:** Chức năng tự động thực hiện bắt tay mật mã (Crypto Handshake) ngay khi có kết nối mới nhằm trao đổi khóa công khai và thiết lập kênh truyền mã hóa trước khi bất kỳ dữ liệu nghiệp vụ nào được phép lưu thông.

1.2.2 Yêu cầu phi chức năng

Bên cạnh các tính năng nghiệp vụ, hệ thống đặc biệt chú trọng vào các yêu cầu phi chức năng nhằm đảm bảo hiệu năng, độ tin cậy và an toàn thông tin tuyệt đối trong môi trường

mạng thực tế:

- **Bảo mật và Toàn vẹn dữ liệu (Security & Integrity):**

- Mọi thông điệp truyền tải trên mạng lưới phải được mã hóa bằng thuật toán chuẩn công nghiệp (AES) với khóa phiên (Session Key) được phân phối an toàn qua cơ chế mã hóa bất đối xứng (RSA).
- Hệ thống phải chống lại được các hành vi đánh tráo, thay đổi nội dung gói tin thông qua việc sử dụng mã xác thực thông điệp (HMAC) kết hợp cùng hàm băm SHA256.
- Tích hợp hệ thống ghi nhận nhật ký kiểm toán chống can thiệp (Tamper-evident Audit Logger) lưu trữ trên cơ sở dữ liệu SQLite, cho phép truy vết chính xác và hệ thống sẽ báo động nếu file log bị chỉnh sửa trái phép từ bên ngoài.
- Có module Phát hiện xâm nhập (Intrusion Detector) để tự động nhận diện và ngắt kết nối các client có hành vi gửi gói tin dị thường, sai cấu trúc hoặc có dấu hiệu tấn công từ chối dịch vụ (DoS).

- **Hiệu năng và Khả năng mở rộng (Performance & Scalability):** Máy chủ phải được thiết kế theo kiến trúc hướng sự kiện (Event-driven) sử dụng vòng lặp bất đồng bộ (Event Loop) kết hợp với mô hình đa luồng (Thread Pool). Điều này đảm bảo luồng chính của hệ thống không bị nghẽn (non-blocking) bởi các thao tác I/O chậm chạp, đáp ứng khả năng xử lý hàng chục nghìn kết nối đồng thời (bài toán C10K) với độ trễ xử lý (Latency) ở mức thấp nhất.

- **Tính tin cậy và Khả năng chịu lỗi (Reliability & Fault Tolerance):** Máy chủ phải có cơ chế xử lý mượt mà các tình huống phân mảnh gói tin TCP (TCP Packet Fragmentation) hoặc dính gói. Nếu phía client đột ngột mất mạng, hệ thống phải tự động nhận diện thông qua cơ chế timeout của Ping/Pong và dọn dẹp tài nguyên (socket, session) để ngăn chặn hoàn toàn rò rỉ bộ nhớ (Memory Leak).

CHƯƠNG 2. NỀN TẢNG LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG

2.1 Kiến trúc mạng và giao thức

2.1.1 Mô hình Client-Server

2.1.2 Giao thức TCP/IP

2.2 Công nghệ mã hóa và bảo mật

2.2.1 Mã hóa đối xứng AES

2.2.2 Mã hóa bất đối xứng RSA

2.2.3 Hàm băm SHA256 và xác thực HMAC

2.3 Công cụ và Thư viện phát triển

CHƯƠNG 3. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ

3.1 Kiến trúc tổng thể hệ thống

3.1.1 Kiến trúc Server

3.1.2 Kiến trúc Client

3.2 Thiết kế giao thức giao tiếp

3.2.1 Cấu trúc gói tin

3.2.2 Luồng xử lý thông điệp

3.3 Thiết kế cơ chế bảo mật

3.3.1 Cơ chế trao đổi khóa (Key Exchange)

3.3.2 Xác thực chứng chỉ số

3.4 Triển khai và Đánh giá

3.4.1 Môi trường triển khai

3.4.2 Đánh giá kết quả đạt được

CHƯƠNG 4. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

4.1 Kết luận

4.2 Hướng phát triển